Fiche technique — à l'attention du service informatique et du responsable de la sécurité informatique

Destinataires : le service informatique (DSI ou direction du numérique, selon l'établissement) et le responsable de la sécurité informatique (RSSI).

Tessera Santé — document de travail du 5 novembre 2026. Application web statique, données chiffrées sur un partage réseau de l'établissement. Licence EUPL-1.2. Code source : https://github.com/rodtrip2/tessera-sante

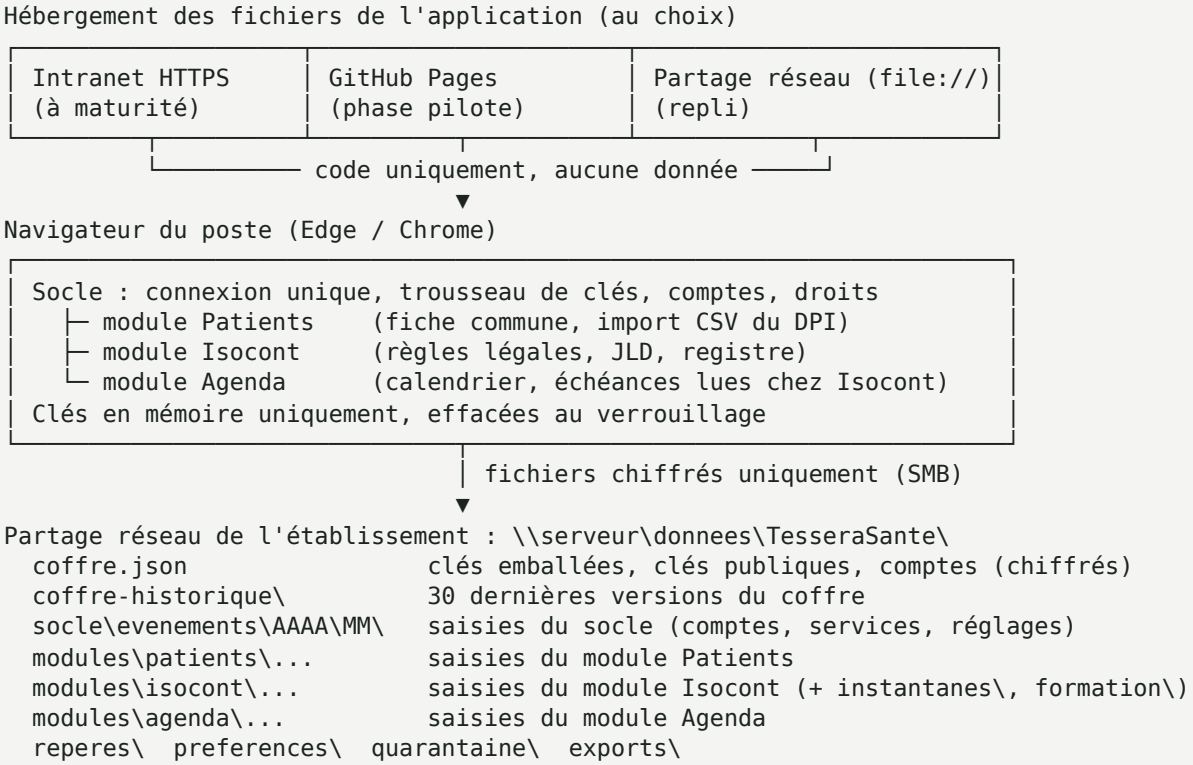
À lire d'abord. Ce document décrit l'**architecture cible** de la plateforme. La colonne ou la mention **« existant »** désigne un mécanisme déjà développé et testé dans le module Isolement et contention (application Suivi-mesures-isocont), repris tel quel par le socle. La mention **« à construire »** désigne un mécanisme défini mais pas encore développé. Les paramètres annoncés pour les éléments à construire pourront être précisés au développement ; la fiche sera alors mise à jour.

1. Résumé

Élément	Choix technique	État
Type d'application	Page web statique (HTML, CSS, JavaScript), sans serveur applicatif, sans base de données, sans étape de construction	existant
Organisation	Un **socle commun** (connexion, comptes, services, droits, chiffrement, stockage, sauvegardes, journal) et des **modules** : Patients, Isolement et contention (Isocont), Agenda du service	à construire (Isocont existant)
Dépendances	Aucune bibliothèque externe ; uniquement les API standard du navigateur	existant
Stockage	Dossier d'un partage réseau (SMB) accédé par l'API *File System Access* du navigateur ; un sous-dossier et un journal par module	existant (un journal) ; à construire (un par module)
Chiffrement	AES-GCM 256 bits côté poste (Web Crypto API), chiffrement en enveloppe ; **une clé par module**, remise seulement aux agents qui y ont droit	existant (une clé) ; à construire (par module)
Authentification	Comptes nominatifs, **connexion unique** pour tous les modules ; mot de passe (PBKDF2-SHA-256, 600 000 itérations), clé de sécurité FIDO2 (WebAuthn, extension PRF) ou code de secours ; mot de passe provisoire à changer à la première connexion	existant
Flux réseau	**Aucun flux sortant** : politique de sécurité du contenu `connect-src 'none'` ; seul le chargement des fichiers de l'application depuis l'hébergement choisi	existant
Échanges avec le DPI	Aucun flux : import manuel d'un fichier CSV exporté du DPI (liste des patients), lu dans le navigateur	à construire

Élément	Choix technique	État
Navigateurs	Microsoft Edge ou Google Chrome récents (Chromium). Firefox et Safari : mode démonstration uniquement	existant
Postes	Windows 10/11 (ou tout système avec Edge/Chrome) ; aucun logiciel à installer	existant
Volumétrie	Environ 1 à 2 Ko par saisie ; ordre de grandeur : quelques dizaines de Mo par an et par unité	existant

2. Architecture



Principe. Le socle ne connaît aucune règle métier ; un module ne voit jamais le coffre, les clés ni les comptes. Le socle remet à chaque module un contexte : l'agent connecté, ses services, ses droits dans ce module, et une fonction d'écriture qui chiffre avec la seule clé de ce module.

Modes d'hébergement

Critère	Intranet HTTPS	GitHub Pages	Partage réseau (`file://`)
Mise en place	Serveur web existant (IIS, Apache, nginx)	Immédiate	Copie de fichiers
Accès Internet requis	Non	Oui (chargement du code)	Non
Clés de sécurité (WebAuthn)	Oui (nom de domaine et certificat valides)	Oui	Non

Critère	Intranet HTTPS	GitHub Pages	Partage réseau (`file://`)
Maîtrise de la version	Service informatique	Porteur du projet	Service informatique
Mise à jour	Par le service informatique, à chaque version	Immédiate, sans intervention du service informatique	Par le service informatique
Usage conseillé	**Production, une fois les modules mûrs**	**Phase pilote**, démonstration	Repli

Une clé de sécurité est liée au nom de domaine du site : elle doit être enregistrée dans chaque mode utilisé. Le mot de passe et le code de secours fonctionnent partout.

Phase pilote : version publiée sur GitHub

Pendant le pilote, l'établissement peut utiliser **la version publiée par le porteur du projet sur GitHub Pages** (`https://rodtrip2.github.io/tessera-sante/`), puis passer à l'hébergement sur l'intranet une fois les modules mûrs.

Ce que GitHub héberge, et ce qu'il n'héberge pas. GitHub sert uniquement les fichiers de l'application (le code). **Les données restent sur le partage de l'établissement**, chiffrées sur le poste ; aucune donnée n'est envoyée à GitHub ni ailleurs (`connect-src 'none'`). Le mode d'hébergement ne change ni le dossier de données, ni les droits NTFS, ni les sauvegardes.

Avantage	Pourquoi c'est utile pendant le pilote
Maîtrise des évolutions par le porteur	Le porteur publie lui-même corrections et ajustements tant que les modules évoluent, sans mobiliser le service informatique à chaque version
Mise à jour immédiate de tous les postes	Bandeau *Recharger la page* à la publication d'une version (vérification existante, désactivable)
Aucune installation	Ni serveur web, ni certificat à préparer pour démarrer le pilote
Traçabilité publique des changements	Chaque modification du code est visible et datée dans l'historique du dépôt ; chaque version est étiquetée, avec ses empreintes SHA-256
Passage à l'intranet sans perte	Le même code est copié sur l'intranet le moment venu ; les données ne bougent pas

Risque propre à ce mode	Parade
Compte GitHub du porteur compromis : une version malveillante pourrait être publiée, avec une politique de sécurité modifiée	**Double authentification activée sur le compte GitHub** (clé de sécurité ou application d'authentification), branche principale protégée, aucun autre contributeur avec droit de publication ; historique public des modifications ; bandeau signalant toute nouvelle version
Postes sans accès Internet, ou GitHub indisponible	Le proxy de l'établissement doit autoriser `https://rodtrip2.github.io` pour les postes concernés ; mise en cache de l'outil sur les postes désignés (travail hors réseau) ; copie de repli prête sur l'intranet ou le partage

Risque propre à ce mode	Parade
Version modifiée sans validation de l'établissement	Journal des versions publié ; possibilité pour l'établissement de figer une version vérifiée en la copiant sur l'intranet

Passage à l'intranet, une fois les modules mûrs : copier le dossier `app` d'une version étiquetée sur le serveur web, vérifier ses empreintes, puis faire réenregistrer les clés de sécurité (liées au nom de domaine). Mots de passe, code de secours et données ne changent pas.

L'usage de GitHub Pages avec des données réelles, même si seul le code y est hébergé, est soumis à l'accord du service informatique, du responsable de la sécurité informatique et du délégué à la protection des données.

3. Socle et modules

Ce que déclare un module

Élément	Exemple (Isocont)
Identité et version	`isocont`, « Isolement et contention »
Accès proposés aux rôles	les accès cochables actuels d'Isocont (report des décisions, envois JLD, registre…)
Types de saisie	début et fin de mesure, pause, envoi JLD…
Réglages par défaut	seuils légaux, listes, masques du décompte
Écrans et onglet d'administration	tableau de bord, mesures, JLD, registre ; onglet *Isocont* de l'administration
Migrations de format	étapes numérotées, rejouables sans effet de bord
Fournitures et besoins	fournit `isocont.echeancesJLD` ; a besoin de `patients`

Activation par service et droits

Un agent voit un module dans un service si **trois conditions** sont réunies : le module est **activé pour ce service** (réglage de l'administrateur, tracé au journal du socle), l'agent est **affecté à ce service**, et il a **un rôle dans ce module**. Le modèle de données prévoit dès le départ un rôle différent selon le service ; l'écran correspondant viendra si le besoin se présente.

L'agent reçoit la clé d'un module dès qu'un de ses services l'active. **À l'intérieur d'un module, le cloisonnement entre services est fait par l'interface**, pas par le chiffrement : ce choix permet de transférer simplement un patient d'un service à l'autre. Un agent techniquement compétent pourrait donc lire les données d'un autre service **du même module** ; il ne peut pas lire un module dont il n'a pas la clé.

Dépendance au module Patients

Les modules qui concernent des patients (Isocont, Agenda) **dépendent** du module Patients : identité, âge, mode d'hospitalisation, séjour. Le socle charge Patients en premier ; un agent qui a accès à Isocont ou à l'Agenda dans un service reçoit aussi la clé de Patients, en lecture. Créer ou corriger une fiche patient est un accès distinct, réglable (IDE, secrétaire et cadre par défaut).

Échanges entre modules

- **Lecture à la volée** (seul mode activé) : quand l'Agenda affiche les échéances JLD, le socle demande au module Isocont de les calculer **sur le poste**, avec la clé d'Isocont que l'agent détient déjà. Rien n'est écrit sur le partage ; aucune copie n'existe hors du module Isocont. Un agent sans accès à Isocont ne voit pas les échéances.
- **Publication** (prévue, **désactivée par défaut**) : le module fournisseur écrirait un extrait minimal chiffré par une clé d'échange propre au service (`echanges\<module>\<service>.enc`). Ce mode crée une copie de données de santé hors du module source : il ne sera activé qu'après avis du délégué à la protection des données.
- Un module n'écrit jamais dans le journal d'un autre. L'import de l'historique d'Isocont transmet ses propositions de fiches à Patients, qui les vérifie et les enregistre lui-même.

4. Prérequis

Postes

- Edge ou Chrome dans une version récente, avec l'API *File System Access* (présente depuis la version 86) et l'extension WebAuthn PRF pour les clés matérielles (Chrome 116 et suivants).
- Accès en lecture et écriture au dossier de données, via un lecteur réseau ou un chemin UNC.
- À chaque nouvelle session, le navigateur peut redemander l'autorisation d'accéder au dossier : c'est un comportement normal.
- Si le site est hébergé sur l'intranet, aucune extension de navigateur ne doit injecter de script dans la page (politique de sécurité stricte).

Clés de sécurité (optionnel, recommandé pour l'administration)

- YubiKey série 5 (FIDO2, fonction *hmac-secret*), micrologiciel 5.2 ou plus récent, ou toute clé FIDO2 compatible PRF.
- Ports USB autorisés pour les clés de sécurité par la politique de l'établissement.
- Sous Windows, la prise en charge de PRF dépend de la version du système et du navigateur : **test obligatoire sur un poste type**.

Serveur web (mode intranet)

- Service de fichiers statiques en HTTPS avec certificat reconnu par les postes.
- En-têtes recommandés (la page déclare déjà sa politique de sécurité dans une balise `meta`) :
- `Content-Security-Policy: default-src 'none'; script-src 'self'; style-src 'self'; img-src 'self' data:; manifest-src 'self'; worker-src 'self'; connect-src 'none'; form-action 'none'; base-uri 'none'; frame-ancestors 'none'`
- `X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`
- `Cache-Control: no-cache` sur `index.html` et les scripts, pour que les postes prennent une mise à jour sans délai.
- Pour la mise en cache de l'outil sur des postes désignés (travail hors réseau) : `sw.js` servi avec son propre en-tête `Content-Security-Policy: default-src 'none'; script-src 'self'; connect-src 'self'` (ce script ne relit que les fichiers du site ; la page garde `connect-src 'none'`).

5. Dossier de données et droits

- Créer un dossier dédié, par exemple `\\serveur\donnees\TesseraSante`, **un par périmètre de confidentialité** (un établissement, un pôle). Tous les modules y sont rangés.
- Donner les droits NTFS **Modifier** au groupe des agents utilisateurs, **aucun droit** aux autres. Le navigateur écrit un fichier temporaire puis le renomme : création, écriture et suppression du temporaire doivent être permises.
- Les droits NTFS s'appliquent au dossier entier : ils ne distinguent pas les modules. La séparation entre modules est assurée par le chiffrement (une clé par module).
- L'application ne supprime jamais un fichier de données. Une suppression manuelle est détectée lorsqu'elle crée un trou dans la chaîne des saisies d'un poste, et les sauvegardes permettent de restaurer le fichier.
- Les droits Windows sont une seconde barrière, indépendante du chiffrement : un fichier copié hors du dossier reste illisible sans moyen de déverrouillage.
- **Exports** (`exports\<service>\<catégorie>`) : décomptes JLD, registres, statistiques, données d'un patient y sont écrits **en clair** (PDF, CSV), jamais écrasés, tracés au journal, purgés selon la durée de conservation réglée par l'établissement (aucune purge par défaut). Le rangement par service permet, si l'établissement le souhaite, des droits NTFS par service sur ces sous-dossiers. *(existant)*

6. Cryptographie

Élément	Mise en œuvre	État
Chiffrement d'un fichier	AES-GCM 256 ; en-tête + IV aléatoire de 96 bits + texte chiffré authentifié ; données associées = nom du fichier (un fichier renommé ou échangé est rejeté)	existant
Clé personnelle de l'agent	Paire de clés ECDH (courbe P-256, Web Crypto API) créée à la première connexion ; partie publique en clair dans le coffre ; partie privée emballée par le mot de passe, la clé de sécurité ou, pour l'administrateur, le code de secours	à construire
Clé de plateforme	AES-GCM 256 ; chiffre les comptes, les services, les rôles et le journal du socle (aucune donnée de patient) ; remise à tous les comptes actifs	à construire
Clé d'un module	AES-GCM 256 ; chiffre les saisies et réglages du module ; remise, chiffrée pour lui (ECDH + HKDF-SHA-256), à chaque agent qui y a droit	à construire
Remise d'une clé	L'administrateur chiffre la clé du module avec la partie publique de l'agent : il n'a pas besoin de connaître son mot de passe, et rien ne passe par un serveur	à construire
Retrait d'un droit	Suppression de l'enveloppe de l'agent, puis **nouvelle génération** de la clé du module pour les saisies à venir. Les générations précédentes restent remises aux agents qui gardent l'accès et à tout nouvel agent : ils lisent tout l'historique ; seul l'agent retiré ne reçoit pas la nouvelle	à construire
Emballage par mot de passe	PBKDF2-SHA-256, 600 000 itérations, sel aléatoire de 128 bits	existant
Emballage par clé de sécurité	Secret WebAuthn PRF (*hmac-secret*) calculé dans la clé, dérivé par HKDF-SHA-256	existant

Élément	Mise en œuvre	État
Code de secours	**Un seul pour la plateforme** ; 20 caractères tirés au hasard (100 bits d'entropie), PBKDF2-SHA-256 ; ouvre la clé de plateforme et toutes les clés de module	existant (principe)
Mot de passe provisoire	16 caractères tirés au hasard (80 bits), remplacé à la première connexion	existant
Mode formation	Jeu de données fictives par module, avec sa propre clé, enveloppée par la clé du module	existant (Isocont)
En mémoire	Clés non exportées vers le stockage du navigateur ; effacées au verrouillage, à la fermeture de l'onglet et après inactivité (10 minutes par défaut)	existant
Écriture du coffre	Contrôle de révision (une modification concurrente est refusée), relecture après écriture, historique des 30 dernières versions	existant

Les mots de passe ne figurent jamais dans le journal. Désactiver un compte supprime ses enveloppes : son mot de passe ne déverrouille plus rien.

7. Saisie simultanée et intégrité *(existant, appliqué à chaque journal)*

- **Une saisie = un fichier**, nommé par l'horodatage, l'identifiant de l'agent et un aléa ; deux saisies simultanées ne peuvent pas s'écraser. L'état est reconstitué en relisant le journal ; les postes relisent les nouveaux fichiers toutes les 5 secondes.
- **Conflits** : deux modifications concurrentes de la même donnée sont détectées ; la première est appliquée, la seconde est conservée et signalée pour arbitrage. Rien n'est perdu.
- **Corrections et annulations** : de nouvelles saisies, avec leur motif ; l'historique reste intact.
- **Chaînage et repères** : chaque saisie référence la précédente du même agent ; chaque agent laisse un repère chiffré dont le compteur ne recule jamais. Le contrôle d'intégrité (connexion, puis toutes les 15 minutes) signale les saisies disparues, les fichiers illisibles et les trous du chaînage, **journal par journal** (socle, puis chaque module).
- **Instantanés** : regroupement chiffré des saisies d'un mois clos, reconstruit au besoin ; les fichiers d'origine font foi.
- **Dossier de secours** (facultatif) : second dossier synchronisé par les postes ou par une tâche robocopy du service informatique, sans suppression ni écrasement d'un fichier plus récent.
- **Travail hors réseau** (postes désignés) : outil mis en cache (`sw.js` , empreintes SHA-256 contrôlées) et copie locale des données chiffrées ; disque chiffré (BitLocker) et liste nominative des postes exigés.
- **Anomalie** : liste des fichiers à restaurer à l'identique ; réparation depuis une copie complète (seuls les fichiers absents ou illisibles) ; quarantaine des fichiers illisibles, jamais de suppression.

8. Imports *(à construire, à partir des imports existants d'Isocont)*

Tous les fichiers importés sont **lus dans le navigateur** ; ils ne sont ni copiés sur le partage, ni envoyés ailleurs.

Import	Fonctionnement
Liste des patients exportée du DPI (CSV ou Excel)	Un agent exporte la liste depuis le DPI et l'ouvre dans Tessera. Attribution des colonnes au moment de l'import (l'export diffère d'un DPI à l'autre), mémorisée dans les réglages ; correspondance des valeurs (sexe, codes d'unité, formats de date) ; aperçu ; enregistrement en un lot annulable. L'IPP est indispensable pour retrouver la fiche d'un import à l'autre.
Historique des mesures (registre du service ou classeur Excel existant)	Import existant d'Isocont, adapté : il prépare un lot pour Patients et un lot pour Isocont, liés par un identifiant d'import commun (annulation conjointe, pas de doublon si relancé).

À prévoir par l'établissement : le fichier exporté du DPI contient des données nominatives en clair sur le poste. Il doit être enregistré dans un dossier aux droits restreints et supprimé après l'import. Aucune interface automatique avec le DPI n'est prévue à ce stade ; des flux HL7 (profil IHE PAM, extension française) pourraient être étudiés plus tard avec le service informatique.

9. Sécurité applicative

- Politique de sécurité du contenu stricte : aucun script externe, aucune requête réseau, aucun formulaire envoyé.
- Interface construite sans interprétation HTML des données saisies (pas d'`innerHTML`) : pas d'injection de script par une donnée, y compris par un fichier importé.
- Aucune donnée de patient conservée dans le navigateur après fermeture ; seuls le dernier dossier ouvert, le service affiché et des préférences d'affichage sont mémorisés localement.
- Code public, sans minification, relisible ; empreinte SHA-256 de chaque fichier publiée avec chaque version.

Modèle de menace

Menace	Couverture
Vol ou copie du dossier de données	Données chiffrées ; inexploitables sans moyen de déverrouillage
Lecture par un agent sans droit sur le partage	Droits NTFS ; chiffrement
Agent lisant un module auquel il n'a pas droit	**Impossible sans la clé du module** : la séparation est cryptographique
Agent lisant un autre service du même module	Filtré par l'interface seulement (choix assumé, voir § 3) ; consultations non tracées, saisies nominatives et chaînées
Agent autorisé outrepassant son rôle dans un module	Rôles appliqués par l'interface ; **sans serveur, ce contrôle n'est pas inviolable** pour un utilisateur techniquement compétent disposant d'un compte valide, mais toute saisie est nominative et visible au journal
Agent retiré ayant gardé une ancienne clé en mémoire	Nouvelle génération de clé : il ne lit pas les saisies postérieures au retrait
Altération d'un fichier	Rejetée (chiffrement authentifié) et signalée

Menace	Couverture
Code de l'application modifié	Hébergement intranet maîtrisé, empreintes SHA-256, `connect-src 'none'` empêchant l'exfiltration par le réseau
Fichier d'export du DPI laissé sur un poste	Hors application : règle d'organisation (dossier restreint, suppression après import)
Poste compromis (enregistreur de frappe, etc.)	Hors périmètre de l'application : relève de la sécurité du poste
Perte de tous les moyens de déverrouillage	Données irrécupérables par conception : deux clés d'administration dont une au coffre, code de secours papier scellé

10. Sauvegarde et restauration

- Sauvegarder le dossier entier comme tout partage de fichiers ; les sauvegardes sont chiffrées de fait.
- Restaurer = remettre les fichiers en place. Les fichiers de saisie sont indépendants : une restauration partielle ne corrompt pas le reste.
- `coffre.json` est indispensable : sans lui, aucune donnée d'aucun module n'est lisible. Il doit figurer dans chaque sauvegarde.
- Tester une restauration lors de la recette, puis une fois par an.

11. Mise à jour et vérification

1. Télécharger la version (dépôt GitHub, étiquette de version).
2. Vérifier les empreintes : `Get-FileHash -Algorithm SHA256 .\app\js\*.js` (PowerShell), à comparer avec le fichier d'empreintes publié.
3. Remplacer le dossier `app` sur le serveur web. Les données ne sont pas touchées. **En phase pilote sur GitHub Pages**, ces étapes sont faites par le porteur du projet à chaque publication ; les postes affichent le bandeau *Recharger la page*.
4. Le format des données est versionné, module par module : une nouvelle version lit les données des versions antérieures.
5. **Mise en production** : à partir d'un dossier vide ; l'historique des mesures et la liste des patients sont importés ensuite (§ 8).

12. Conformité

Sujet	Analyse	À valider par
Hébergement de données de santé (art. L. 1111-8 du code de la santé publique)	Les données restent sur l'infrastructure de l'établissement, sans prestataire. La certification d'hébergeur de données de santé (HDS) s'impose à qui propose un service d'hébergement ; elle ne devrait donc pas s'appliquer ici, mais tout projet est examiné au cas par cas (Agence du numérique en santé).	Délégué à la protection des données (DPO, référent RGPD), service informatique

Sujet	Analyse	À valider par
RGPD	**Un traitement par module** à inscrire au registre des traitements (Patients, Isocont, Agenda) ; analyse d'impact probablement requise (liste CNIL). Minimisation : aucune donnée clinique ; la fiche patient ne garde que ce qui sert à plusieurs modules.	Délégué à la protection des données
Registre légal (art. L. 3222-5-1 du code de la santé publique)	Le module Isocont produit le registre ; son statut de support officiel relève d'une décision de l'établissement.	Direction
Hébergement du code sur GitHub pendant le pilote	Seul le code est servi par GitHub ; aucune donnée n'y transite. Double authentification sur le compte du porteur.	Service informatique, responsable de la sécurité informatique, délégué à la protection des données
Politique de sécurité	Navigateurs, clés USB, droits du partage, postes hors réseau, fichiers exportés du DPI.	Responsable de la sécurité informatique

13. Limites connues

- Contrôle des rôles et cloisonnement entre services d'un même module côté poste (voir le modèle de menace).
- Pas d'interface automatique avec le DPI : import manuel d'un fichier.
- Pas de notification hors de l'application (courriel, SMS) : les alertes s'affichent à l'ouverture.
- Firefox et Safari ne permettent pas d'ouvrir un dossier réseau.
- Pas de connexion avec la session Windows à ce stade (étudiée pour plus tard).

14. Recette technique — liste de contrôle

- ☐ Empreintes SHA-256 des fichiers vérifiées.
- ☐ Phase pilote : `https://rodtrip2.github.io` autorisé par le proxy pour les postes concernés ; double authentification du compte GitHub du porteur confirmée.
- ☐ Production : application servie en HTTPS sur l'intranet ; certificat reconnu par les postes.
- ☐ Dossier de données créé ; droits NTFS limités au groupe des utilisateurs.
- ☐ Poste type : ouverture du dossier, initialisation, saisie, relecture depuis un second poste.
- ☐ Saisie simultanée depuis deux postes : aucune perte, conflit signalé.
- ☐ Module activé dans un service et pas dans un autre : un agent du second service ne le voit pas.
- ☐ Agent sans droit sur un module : les fichiers de ce module restent illisibles pour son compte.
- ☐ Retrait d'un droit : l'agent retiré ne lit plus les nouvelles saisies ; un autre agent lit tout l'historique.
- ☐ Import d'une liste de patients exportée du DPI (données fictives) : colonnes attribuées, aperçu, annulation.
- ☐ Clé de sécurité enregistrée puis utilisée pour déverrouiller (si retenue).
- ☐ Sauvegarde puis restauration du dossier testées.
- ☐ Vérification qu'aucune requête sortante n'est émise (outils de développement, onglet Réseau).
- ☐ Mode formation : seules les données fictives s'affichent.